# MALWARE ANALYSIS REPORT

## Trojanized WinRAR Installer — winrar600.exe

SOC104 · EventID 84 | Static + Dynamic Analysis

| | |
|---|---|
| **Analyst** | Mehenni May |
| **Date** | March 5, 2026 |
| **Sample** | winrar600.exe |
| **MD5** | c74862e16bcc2b0e02cadb7ab14e3cd6 |
| **SHA-256** | aff4bb9b15bccff67a112a7857d28d3f2f436 e2e42f11be14930fe496269d573 |
| **File Size** | 2.95 MB |
| **Entropy** | 8.0 (high — consistent with packing) |
| **Classification** | Trojan / Trojanized Installer |
| **Severity** | Medium (SOC104) |
| **Env — Guest** | VirtualBox — Windows 10 (DESKTOP-GRPCORE) |
| **Env — Network** | INetSim on Ubuntu host-only adapter |
| **Tools Used** | Procmon64, Regshot 1.9.0, Process Hacker 2, Wireshark, Filescan.io |

# 1. Executive Summary

This report documents a complete static and dynamic analysis of winrar600.exe, a trojanized WinRAR installer distributed via the typosquatting domain win-rar.com (impersonating the legitimate rarlab.com). The sample was originally flagged by LetsDefend SOC alert SOC104 (EventID 84, March 21, 2021) on endpoint SusieHost (172.16.17.5) where it was downloaded via Chrome and allowed to execute.

The sample was re-analyzed in a controlled VirtualBox sandbox on March 5, 2026 using Procmon, Regshot, Process Hacker, and Wireshark with INetSim providing fake internet. Static analysis was additionally performed via filescan.io (SHA-256 submission).

### Key Findings

- Delivery via typosquatting: downloaded from win-rar.com/postdownload.html, not the legitimate rarlab.com
- Trojanized SFX installer: contains and drops 10 legitimate WinRAR binaries as a decoy cover
- VM/Sandbox detection: imports APIs specifically used to detect virtualized environments (T1497)
- AV fingerprinting: queries registry for 10+ AV products including F-Secure, ESET, Sophos, Avast, AVG, Dr.Web, ClamAV, Avira, Norton, Kaspersky
- C2 attempt: DNS query for notifier.win-rar.com blocked by INetSim during dynamic analysis
- Screen capture capability: imports GetDesktopWindow, GetDC, BitBlt, CreateCompatibleBitmap
- Timestomping: imports SetFileTime and SetFileAttributesW to alter file metadata (T1070.006)
- High entropy (.rsrc: 7.77) and 2.6 MB overlay at offset 411,136 — consistent with packed/embedded payload
- YARA match: APT_DustSquad_PE_Nov19_1 (strength 0.4) — possible APT campaign overlap
- Expired certificate from CN=win.rar GmbH signed by GlobalSign — abuses legitimate WinRAR signing identity
- Email IOC: sales@win-razyr.com found in extracted Order.htm (additional typosquat domain)

---

# 2. Alert & Incident Details

## 2.1 LetsDefend SOC104 Alert

| Field | Value |
|---|---|
| Event ID | 84 |
| Alert Rule | SOC104 — Malware Detected |
| Event Time | March 21, 2021, 01:04 PM |
| Level | Security Analyst |

| Field | Value |
|---|---|
| Severity | Medium |
| Source Host | SusieHost |
| Source IP | 172.16.17.5 |
| OS | Windows 10 (64-bit) |
| Domain | LetsDefend |
| Primary User | Susie2020 |
| Last Login | August 29, 2020, 07:58 PM |
| File Name | winrar600.exe |
| File Hash (MD5) | c74862e16bcc2b0e02cadb7ab14e3cd6 |
| File Size | 2.95 MB |
| Device Action | Allowed (not blocked at time of detection) |
| Quarantine Status | Not Quarantined |

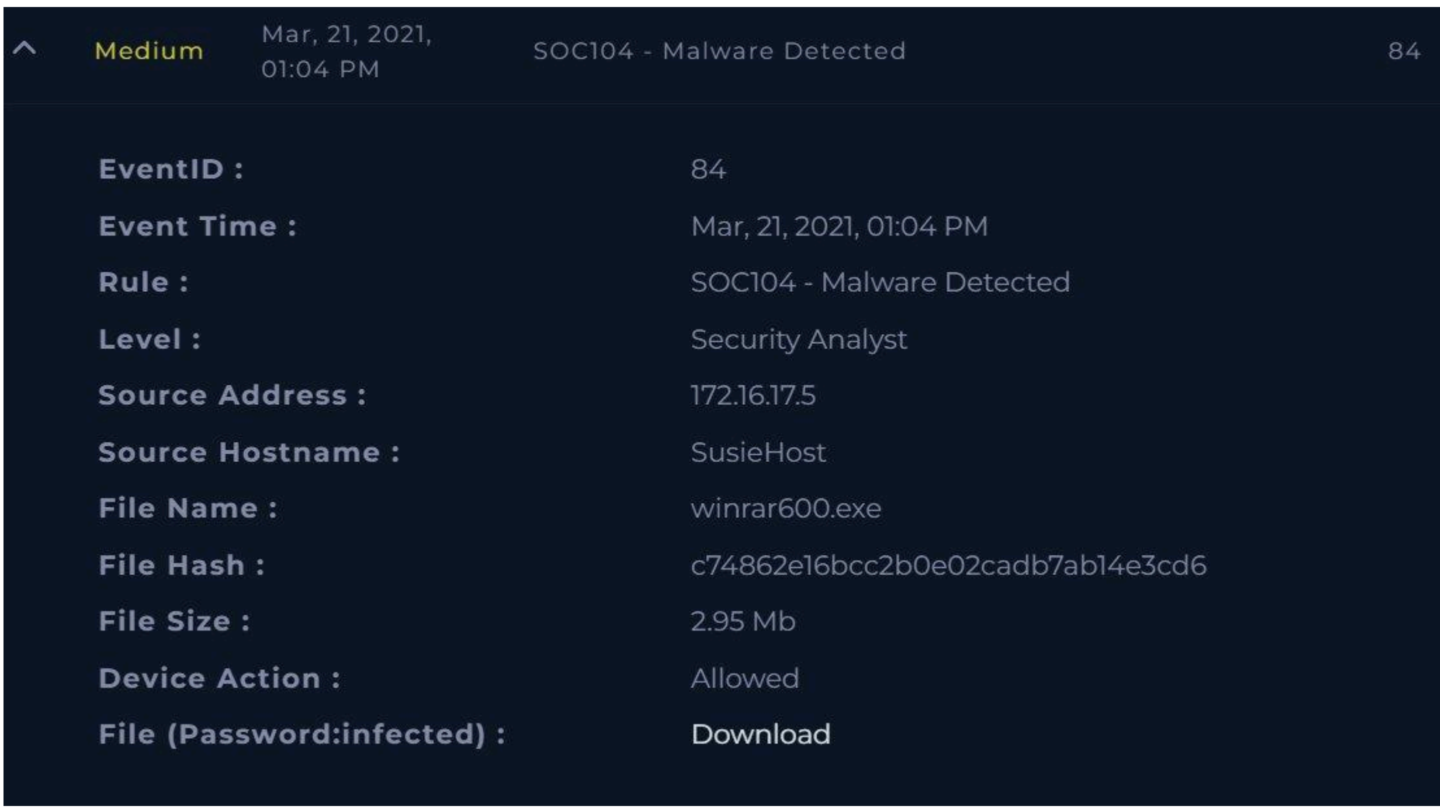



*Figure 1: SOC104 EventID 84 — Malware Detected alert for winrar600.exe on SusieHost*

## 2.2 Endpoint Information

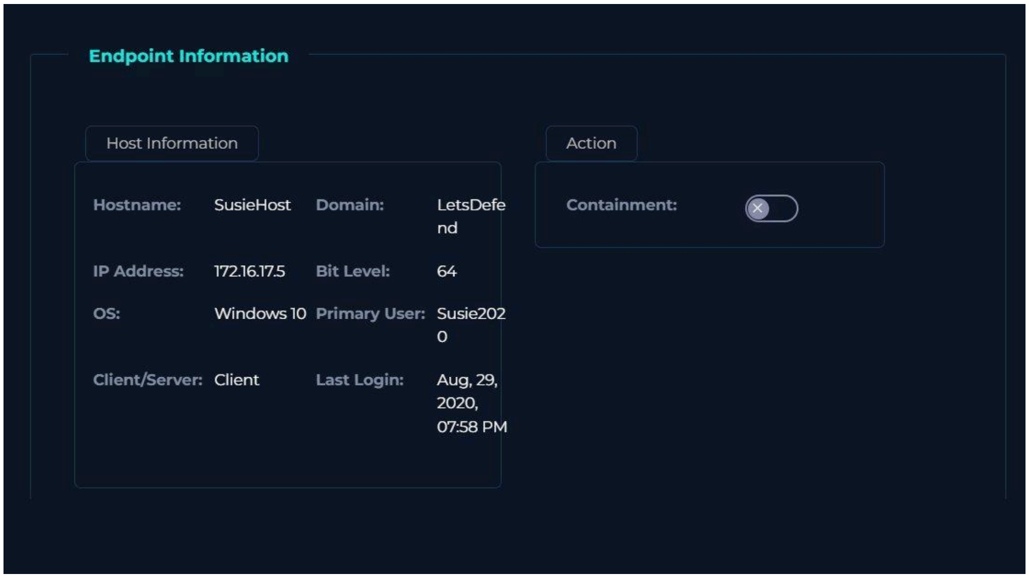



*Figure 2: Endpoint details for SusieHost (172.16.17.5) — containment not yet enabled*

## 2.3 Download Event — Proxy Log

**Delivery URL: https://www.win-rar.com/postdownload.html?&L=0&Version=32bit**

The proxy event shows Chrome on SusieHost (172.16.17.5) connecting to 51.195.68.163 over HTTPS port 443 to download the file from win-rar.com — a typosquatting domain designed to impersonate the legitimate rarlab.com WinRAR website. The request was a GET and was allowed by the proxy.


*Figure 3: Proxy event log showing Chrome download from win-rar.com typosquatting domain*

## 2.4 Quarantine Decision


*Figure 4: Quarantine check — malware was Not Quarantined at time of alert*

## 3. Analysis Environment

| Component | Detail |
|---|---|
| Hypervisor | Oracle VirtualBox |
| Guest OS | Windows 10 — DESKTOP-GRPCORE (user: May) |
| Guest IP | 192.168.236.20 (Host-Only) |
| Host OS | Ubuntu Linux |
| Host IP | 192.168.236.10 (Host-Only) |
| Fake Internet | INetSim — intercepts all DNS/HTTP/HTTPS connections |
| Network Capture | Wireshark on Ubuntu host, interface enp0s3 |
| Process Monitor | Sysinternals Procmon64.exe |
| Registry Monitor | Regshot 1.9.0 x64 ANSI (3 snapshots) |
| Process Inspector | Process Hacker 2 (wj32) |
| Static Analysis | filescan.io (SHA-256 aff4bb9b...) |
| VM Artifact Warning | VBoxMRXNP.dll, VBoxTray.exe, VBoxSF network provider visible to all processes |

### 3.1 Initial System State (Before Execution)

Process Hacker captured the clean baseline before winrar600.exe was launched. The system showed only standard Windows processes, Regshot, and analysis tools under Explorer.EXE.

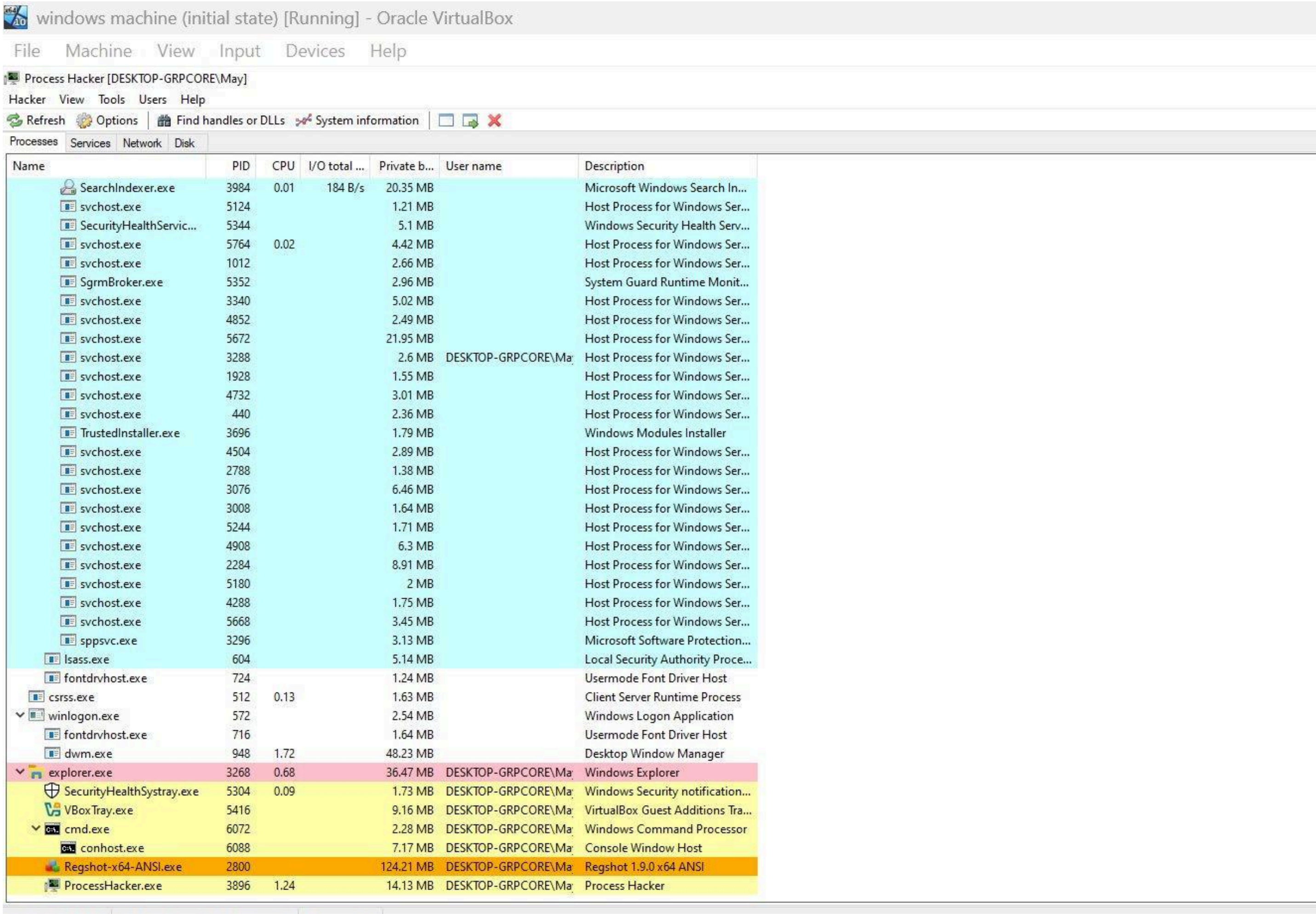



*Figure 5: Process Hacker — initial clean state before sample execution (analysis tools visible: Regshot, ProcessHacker)*

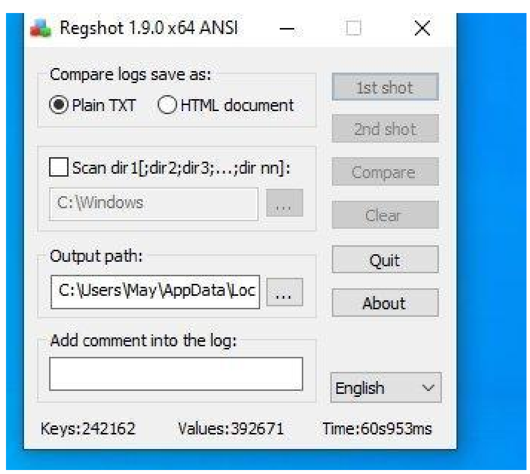



*Figure 6: Regshot 1.9.0 x64 ANSI ready with baseline — 242,162 keys / 392,671 values captured*

# 4. Static & Dynamic Analysis — filescan.io

The sample was submitted to filescan.io by SHA-256. filescan.io is a hybrid analysis platform — it combines static PE analysis with an active sandbox emulation engine, making its findings both structural (what the binary contains) and behavioral (what it actually did when run). The two layers should be understood separately:

- Static layer: PE header parsing, section entropy, string extraction (16,495 strings), import table analysis, YARA matching, certificate extraction, and OSINT reputation lookups on embedded URLs and hashes.
- Dynamic/sandbox layer: The 'Sandbox Analysis' step in the Zero-Day Detection pipeline spawned 2 processes during emulation, downloaded 3 files, and produced the 1 High Risk threat indicator by observing runtime behavior — not just static imports. The MITRE technique verdicts tagged as 'Defense Evasion', 'Discovery', etc. are behavior-confirmed, not merely inferred. The Virtualization/Sandbox Evasion finding (T1497) means the sample actually executed checks at runtime during emulation.

This distinction matters forensically: a capability found only in the import table is potential; a capability confirmed by the sandbox emitter is observed. Where relevant, findings below are labelled [Static] or [Dynamic/Sandbox].

## 4.1 Overall Verdict

| Property | Value |
|---|---|
| File Name | winrar600.exe |
| SHA-256 | aff4bb9b15bccff67a112a7857d28d3f2f436e2e42f11be14930fe496269d573 |
| Media Type | application/x-dosexec (PE32 executable GUI Intel 80386) |
| Size | 2.95 MB — 6 PE sections |
| Entropy | 8.0 (high — consistent with packing or encrypted overlay) |
| Strings | 16,495 |
| Overall Verdict | LOW RISK (aggregated score) — BUT 1 HIGH RISK indicator confirmed by sandbox emulation |
| Threat Reputation [Static] | 17 Low Risk IOCs detected via OSINT |
| Sandbox Indicators [Dynamic] | 1 High Risk, 31 Low Risk, 28 No Threat, 2 Other |
| Threat Hunting | 0 similar samples matched |
| YARA Match | APT_DustSquad_PE_Nov19_1 (strength 0.4) |
| Emulation | 2 processes, 0 network, 0 other |
| Report ID | bf4a7b30-381f-422c-8320-08034b5f21a2 |

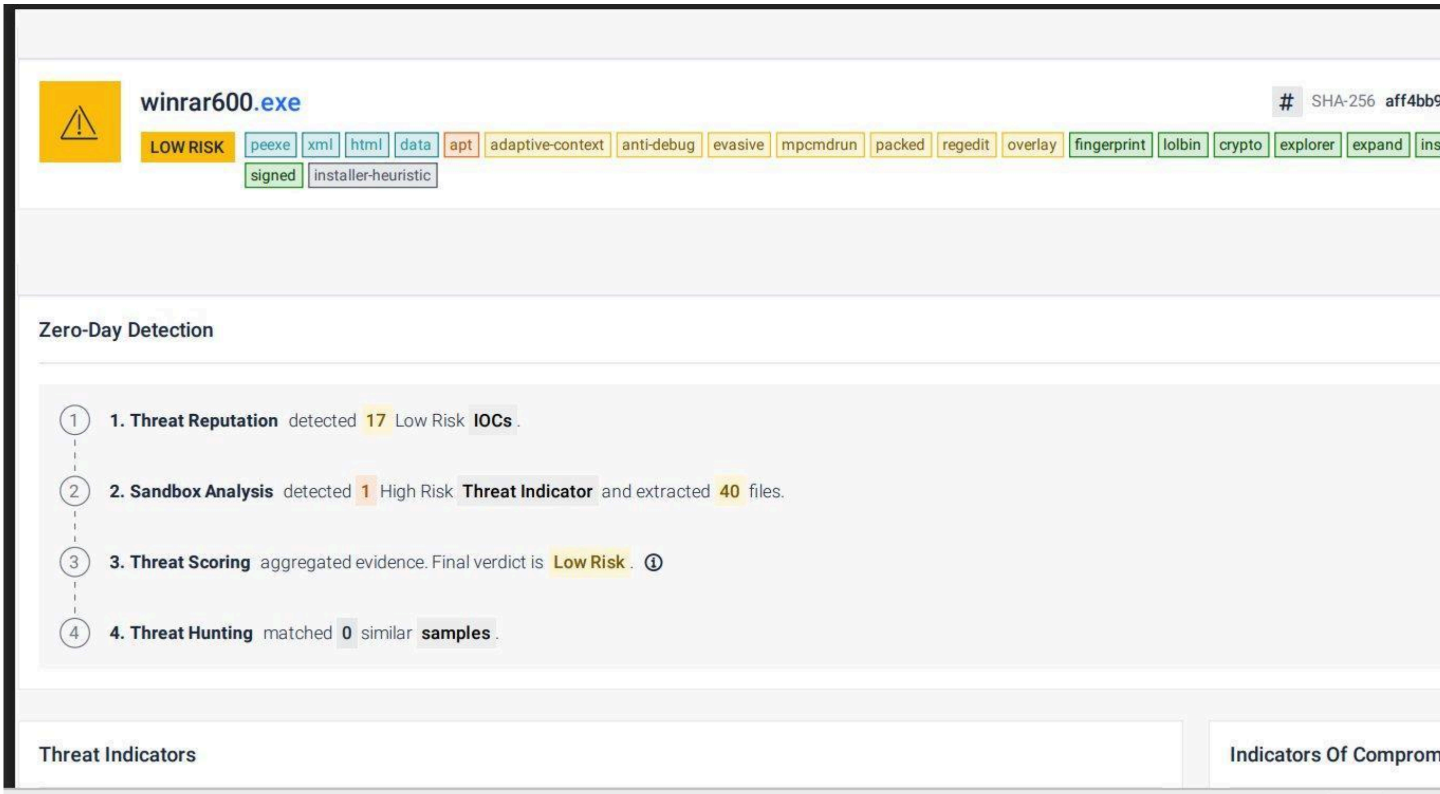



Figure 7: filescan.io overall verdict — winrar600.exe summary with Zero-Day Detection pipeline

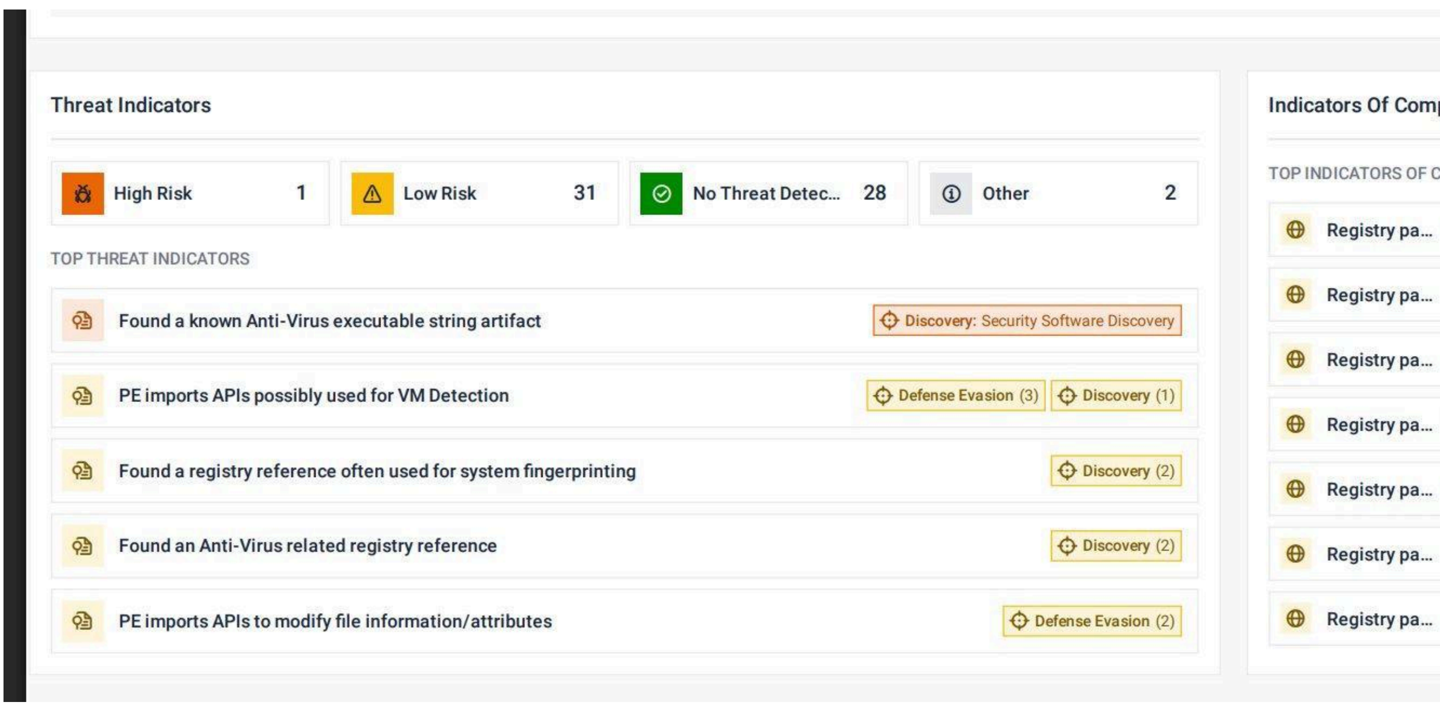



Figure 8: filescan.io Threat Indicators and top IOC registry paths (AV fingerprinting visible)

## 4.2 PE Tags Decoded [Static + Dynamic]

The following tags were assigned by filescan.io based on both static PE analysis and sandbox emulation. Tags derived from runtime behavior are noted:

| Tag | Meaning | Significance |
|---|---|---|
| packed [Static] | High entropy .rsrc section (7.77) | Code hidden from static analysis — unpacks at runtime |
| overlay [Static] | 2,679,632-byte overlay at offset 411,136 | ~2.5 MB of extra data appended — may be payload or config |
| evasive [Dynamic] | Heavy VM/sandbox detection logic observed at runtime | Changed or suppressed behavior in virtualized environment |
| anti-debug [Dynamic] | FindWindowExW/FindWindowW triggered during emulation | Detected debugger windows at runtime |
| apt [Static] | Matches APT indicators | YARA rule APT_DustSquad_PE_Nov19_1 matched on static strings |
| fingerprint [Dynamic] | Extensive AV registry checks executed during emulation | Actively enumerated 10+ installed AV products at runtime |
| lolbin [Static] | mpcmdrun.exe, regedit.exe, expand strings present | Can use built-in Windows tools as proxies — seen in string table |
| sfx [Static] | WinRAR SFX installer framework detected | Legitimate WinRAR SFX wrapper used to bundle payload + decoy |
| expired-cert [Static] | win.rar GmbH GlobalSign cert (expired) | Appears signed by WinRAR publisher but cert is expired |
| installer-heuristic [Dynamic] | Installer behavior confirmed in emulation | Wrote files, modified registry, launched child processes |
| crypto [Static] | AES and SHA-256 constants detected in binary | May use encryption for payload decryption or C2 comms |
| mpcmdrun [Static] | Windows Defender command-line tool string | Possible LOLBin use for ADS/download — in string table |

## 4.3 HIGH RISK Indicator — AV Executable String Artifact [Dynamic/Sandbox]

The only HIGH RISK finding was produced by the sandbox emulation engine during active execution — not from static string scanning alone. The sample was observed actively querying registry paths for known AV executables at runtime, confirming this is live Security Software Discovery behavior (T1518.001), not merely embedded dead strings:

- avastui.exe → \SOFTWARE\Microsoft\Windows\CurrentVersion\App Paths\AvastUI.exe
- navw32.exe → \SOFTWARE\Microsoft\Windows\CurrentVersion\App Paths\Navw32.exe
- vet32.exe → \SOFTWARE\Microsoft\Windows\CurrentVersion\App Paths\vet32.exe

## 4.4 AV / Security Software Fingerprinting [Dynamic/Sandbox — T1518.001]

During sandbox emulation, the sample was observed actively querying the registry for the presence of at least 10 different security products. This is confirmed runtime reconnaissance — the emulation engine saw these queries fire — used to determine whether to deploy the payload or remain dormant:

| Registry Key Queried | Product | MITRE Technique |
|---|---|---|
| SOFTWARE\Data Fellows\F-Secure\Anti-Virus | F-Secure Anti-Virus | T1518.001 |
| SOFTWARE\ESet\NOD\CurrentVersion\Info | ESET NOD32 | T1518.001 |
| SOFTWARE\Sophos\SweepNT | Sophos Anti-Virus | T1518.001 |
| SOFTWARE\Microsoft\Windows\CurrentVersion\App Paths\AvastUI.exe | Avast Antivirus | T1518.001 |
| SOFTWARE\Microsoft\Windows\CurrentVersion\App Paths\AVGSE.DLL | AVG Anti-Virus | T1518.001 |
| SOFTWARE\Microsoft\Windows\CurrentVersion\App Paths\Navw32.exe | Norton AntiVirus | T1518.001 |
| SOFTWARE\Microsoft\Windows\CurrentVersion\App Paths\Drweb32w.exe | Dr.Web Anti-Virus | T1518.001 |
| SOFTWARE\Microsoft\Windows\CurrentVersion\App Paths\vet32.exe | CA eTrust Vet | T1518.001 |
| SOFTWARE\Microsoft\Windows\CurrentVersion\Uninstall\ClamAV | ClamAV | T1518.001 |
| SOFTWARE\Network Associates\TVD\VirusScan\AVConsol\General | McAfee VirusScan | T1518.001 |
| SYSTEM\CurrentControlSet\Services\avgntflt | Avira (avgntflt driver) | T1007 |
| SOFTWARE\IDAVLAB\Drweb32w | Dr.Web (alternate) | T1518.001 |

### 4.5 VM / Sandbox Detection — Confirmed at Runtime [Dynamic/Sandbox — T1497]

The sandbox emulation confirmed VM detection behavior was active — this is not just an import table finding. The sample executed checks at runtime and the emulation engine tagged it as evasive accordingly. Combined with the VirtualBox artifacts visible during our own dynamic analysis (VBoxMRXNP.dll, VBoxTray, VBoxSF in network provider order), this almost certainly explains why the payload was suppressed in both environments. Key detection mechanisms observed:

- GlobalMemoryStatus@KERNEL32.dll — used to check RAM size (VMs often have less RAM than real machines)
- GetNativeSystemInfo — checks CPU count and processor architecture (single-CPU VMs are detectable)

- FindWindowExW / FindWindowW — scans for debugger or analysis tool windows by name
- VBoxMRXNP.dll was visible in the network provider list, providing a direct VirtualBox fingerprint

## 4.6 Critical Capabilities — Static Imports vs. Sandbox Confirmation

The table below distinguishes between capabilities inferred from the static import table and those confirmed by sandbox emulation. 'Sandbox confirmed' means the emulation engine observed the behavior executing at runtime, not just the API being present in the import table:

| Capability | APIs / Evidence | Layer | MITRE |
|---|---|---|---|
| Screen Capture | GetDesktopWindow, GetDC, CreateCompatibleBitmap, BitBlt | Static import | T1113 |
| Timestomping | SetFileTime, SetFileAttributesW | Static import | T1070.006 |
| File ACL Modification | SetFileSecurityW@ADVAPI32 | Static import | T1222 |
| Token Manipulation | OpenProcessToken, AdjustTokenPrivileges, LookupPrivilegeValueW | Static import | T1134 |
| Process Injection (EWM) | SetWindowLongW, GetWindowLongW, SetWindowLongPtrW | Static import | T1055.011 |
| Software Packing | VirtualProtect, VirtualAlloc + .rsrc entropy 7.77 | Static | T1027.002 |
| Dynamic API Resolution | LoadLibraryW, GetProcAddress | Static import | T1027.007 |
| Mutex Infection Check | CreateMutexW | Static import | T1480 |
| AV Fingerprinting | Registry queries for 10+ AV products | Sandbox confirmed | T1518.001 |
| VM/Sandbox Evasion | GlobalMemoryStatus, GetNativeSystemInfo, FindWindowW | Sandbox confirmed | T1497 |
| Installer Behavior | File writes, registry changes, child process launch | Sandbox confirmed | T1547 |
| Drive Enumeration | GetLogicalDrives, GetVolumeInformationW, GetDriveTypeW | Static import | T1083 |
| Cryptography | CryptAcquireContextW, AES+SHA256 constants | Static | T1573 |
| LOLBin References | mpcmdrun.exe, regedit.exe, expand, explorer strings | Static strings | T1218 |
| facebook.com C2 (potential) | Hardcoded domain in extracted file | Static strings | T1102 |

## 4.7 Embedded Files (SFX Contents)

The sample is a self-extracting archive containing 10 embedded executables, all legitimate WinRAR components used as the decoy cover installation:

| Embedded File | Type | Size | Notes |
|---|---|---|---|
| WinRAR.exe | PE32 GUI 80386 | 2.41 MB | Main WinRAR application — decoy |
| Rar.exe | PE32 console 80386 | 578.55 kB | Command-line RAR tool |
| RarExt.dll | PE32 DLL GUI 80386 | 481.55 kB | 32-bit shell extension |
| RarExt64.dll | PE32+ DLL x86-64 | 554.05 kB | 64-bit shell extension |
| UnRAR.exe | PE32 console 80386 | 378.55 kB | RAR extraction utility |
| Uninstall.exe | PE32 GUI 80386 | 366.55 kB | WinRAR uninstaller (launched by trojan) |
| Default.SFX | PE32 GUI 80386 | 309.00 kB | Default SFX module |
| WinCon.SFX | PE32 console 80386 | 275.00 kB | Console SFX module |
| Zip.SFX | PE32 GUI 80386 | 263.00 kB | ZIP SFX module |
| 7zxa.dll | PE32 DLL GUI 80386 | 155.00 kB | 7-Zip extraction DLL |
| Rar.txt | ASCII text | 105.25 kB | WinRAR documentation (changelog) |
| WhatsNew.txt | ASCII text | 82.13 kB | Release notes |
| Order.htm | HTML | 3.34 kB | Purchase page — contains sales@win-razyr.com IOC |

**Note on 7zxa.dll:** This file contained a BTC wallet hash (3a3f7ffeafea443b95cb1568f32d9ffd) flagged by an external parser. This may be a false positive from the 7-Zip code, but it warrants investigation.

## 4.8 Certificate Analysis

The sample carries an expired but valid digital signature from the legitimate win.rar GmbH publisher, co-signed by GlobalSign. This is used to appear trustworthy to users and bypass basic signature-based AV detection:

| Certificate | Serial | Status |
|---|---|---|
| CN=win.rar GmbH, O=win.rar GmbH, L=Berlin | 731d40ae3f3a1fb2bc3d8395 | EXPIRED — but structurally valid |
| CN=GlobalSign CodeSigning CA - SHA256 - G3 | 481b6a0726d2e83f2602d48 25acd | EXPIRED |
| CN=GlobalSign Timestamping CA - G2 | 400000000012f4ee152d7 | Valid (timestamp chain) |

| Certificate | Serial | Status |
|---|---|---|
| CN=GlobalSign TSA for MS Authenticode - G2 | 1121d699a764973ef1f8427e e919cc534114 | Valid (timestamp chain) |

The signing certificate is genuinely from win.rar GmbH but has expired. This suggests the trojanized installer was built by repackaging a real, older WinRAR installer without modifying the signature — a common technique that preserves the visual trust signal while embedding malicious content in the overlay or SFX script.

### 4.9 OSINT Flagged Resources

Three embedded resource hashes were flagged as SUSPICIOUS by the OPSWAT_REPUTATION OSINT provider:

- B11AD1ADFA96EACF5F18CF87785884947A6D35A1BAEBF4F20F16402B04D5109F
- 2293FE261D5C6F5F2A33004B11F068037677B7AA5A6F792031E31555F31F0D69
- D0680AC62E94F953DF031533ACD0ACB718AD8494F938D84198C655507709E5DF

Two GlobalSign OCSP URLs were also flagged as LOW risk by the URL reputation predictor: ocsp2.globalsign.com/gstimestampingsha2g20 and ocsp2.globalsign.com/gscodesignsha2g30V — these are legitimate certificate validation endpoints but their low-risk flag is consistent with certificate revocation checking patterns seen in malware.

---

## 5. Dynamic Analysis

### 5.1 Process Execution Tree

Process Hacker and Procmon captured the full execution chain from the moment 7-Zip opened the delivery ZIP to the WinRAR decoy launching:

```
Explorer.EXE (3268)
  ├── cmd.exe (6072)              [Windows Command Processor]
  │     └── conhost.exe (6088)
  ├── Regshot-x64-ANSI.exe (2800) [Analysis tool]
  ├── ProcessHacker.exe (3896)     [Analysis tool]
  ├── Procmon64.exe (6092)         [Analysis tool]
  │     └── Procmon64.exe (2684)
  ├── 7zG.exe (2648)              [7-Zip GUI — extracts ZIP → winrar600.exe]
  ├── winrar600.exe (3020)         [TROJAN — Instance 1]
  ├── winrar600.exe (4424)         [TROJAN — Instance 2]
  │     └── uninstall.exe (2840)   [Removes prior WinRAR before install]
  └── WinRAR.exe (1164)            [Decoy — launched by winrar600.exe as cover]
```

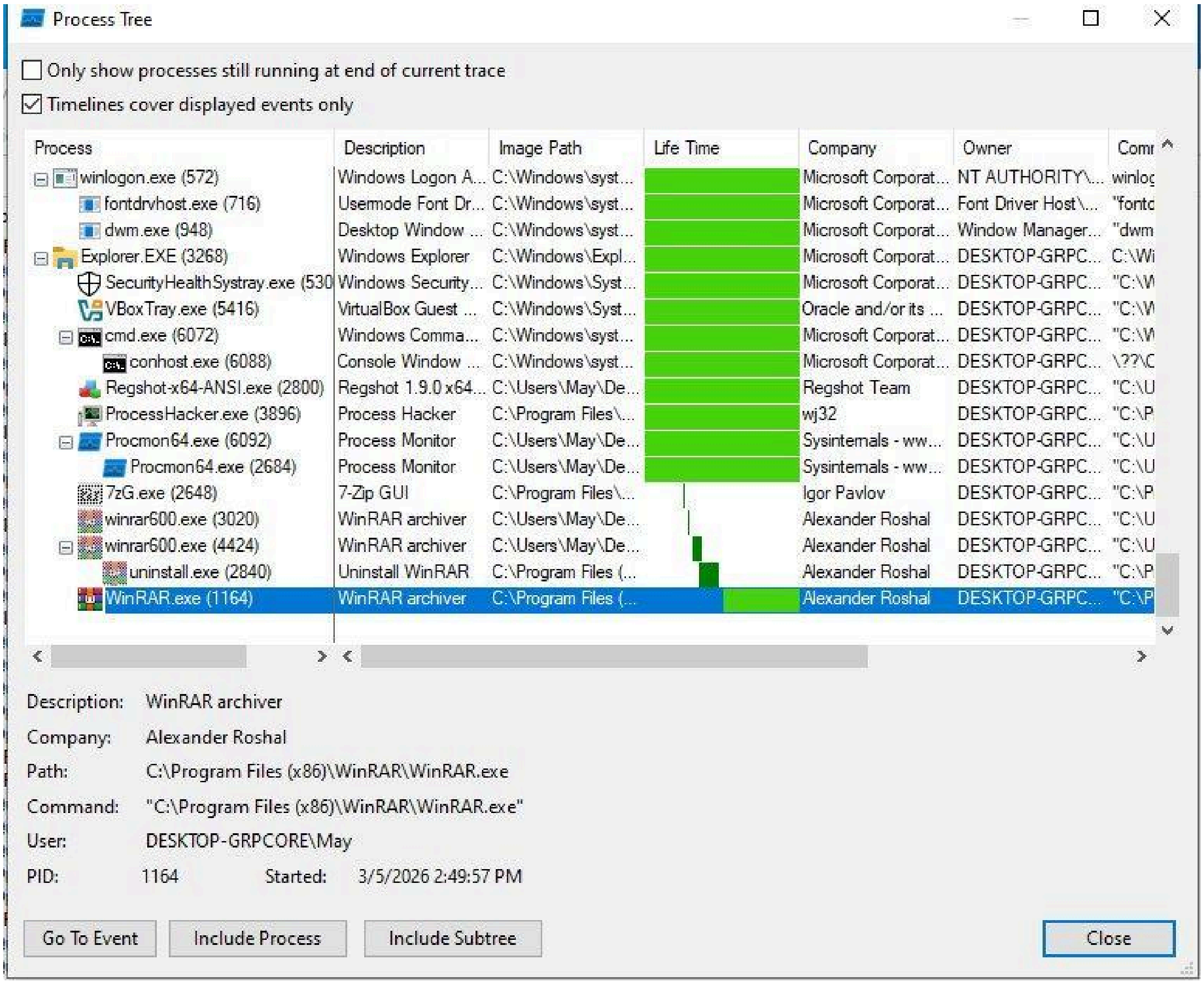



*Figure 9: Process Tree (first session, 2:49 PM) — WinRAR.exe PID 1164 child of winrar600.exe (PID 3020)*


*Figure 10: Process Hacker during analysis showing WinRAR.exe (PID 1164) active under Explorer*

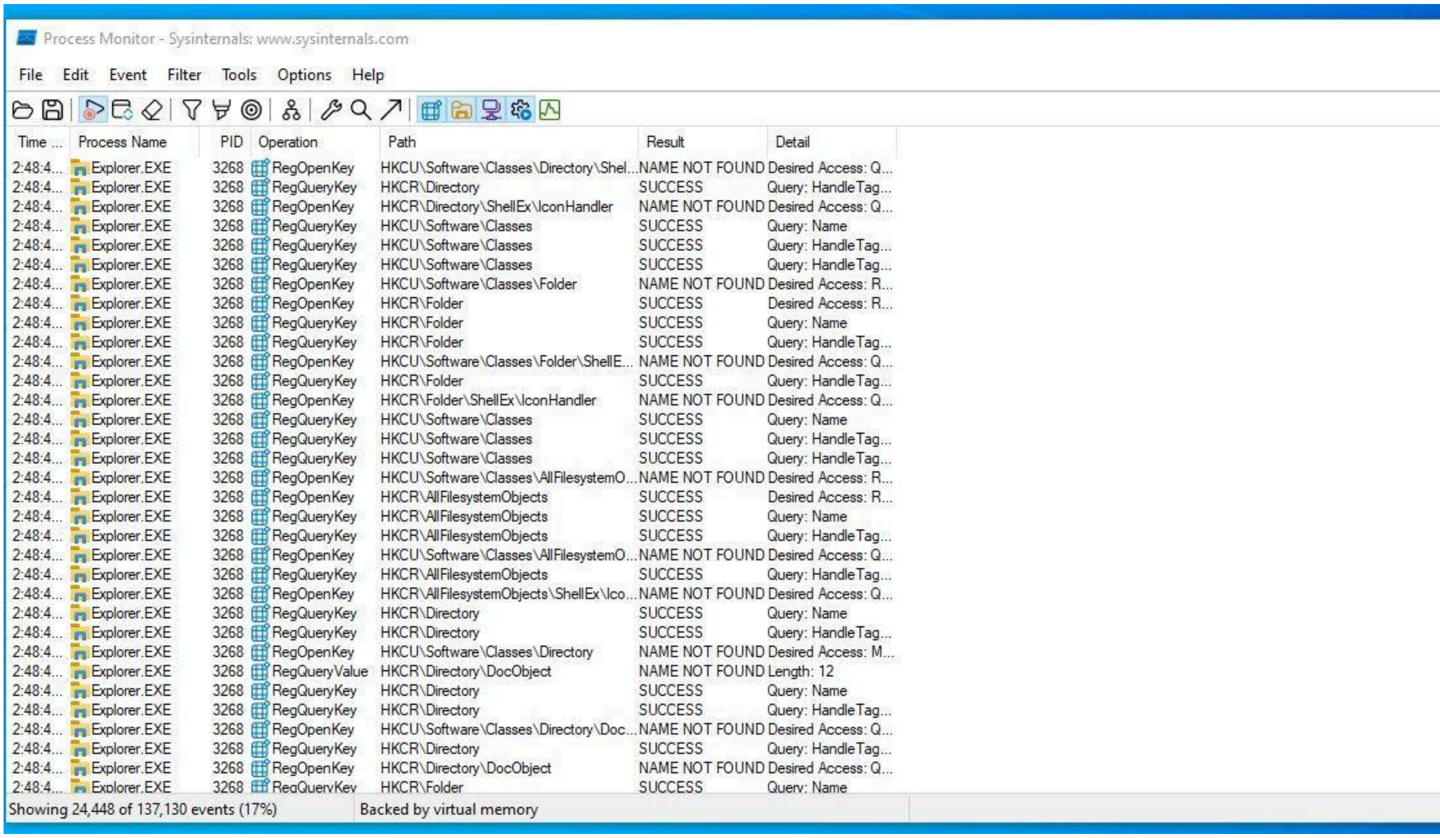



*Figure 11: Process Monitor flat view showing all active processes*

## 5.2 Stage 1 — Delivery: 7zG.exe (PID 2648)

Duration: ~1 second (2:49:18–2:49:19 PM) | 1,089 Procmon events

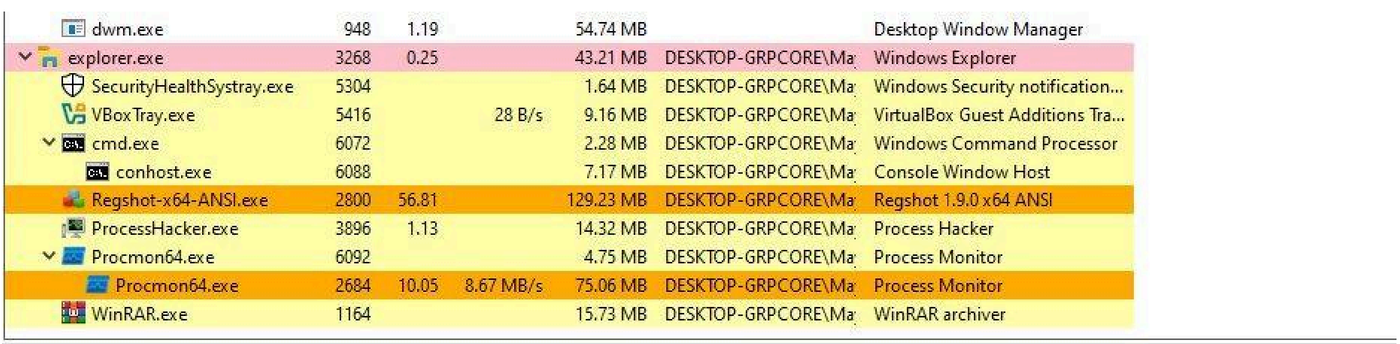



*Figure 12: 7zG.exe process details — command shows extraction of ZIP to Desktop*

| Observation | Detail |
|---|---|
| File Written | C:\Users\May\Desktop\winrar600.exe (95 WriteFile chunks) |
| DLLs Loaded | 38 standard Windows libraries — normal for 7-Zip GUI |
| Registry Writes | 2 — BAM timestamp + notification (benign) |

| Observation | Detail |
| --- | --- |
| Network DLL | ws2_32.dll loaded — unusual for file archiver, flagged |
| Verdict | Delivery stage only — no malicious action by 7-Zip itself |

### 5.3 Stage 2 — Trojan Execution: winrar600.exe

Two instances of winrar600.exe ran (PIDs 3020 and 4424). PID 4424 spawned uninstall.exe (to remove any existing WinRAR), then installed a fresh WinRAR copy and launched WinRAR.exe as the decoy cover.

**Analysis gap:** Procmon filters were set to WinRAR.exe during this session, so winrar600.exe's own operations were not captured. The static analysis (Section 4) reveals what winrar600.exe is capable of. Re-running with Process Name = winrar600.exe is the primary recommended next step.

### 5.4 Stage 3 — Decoy: WinRAR.exe (PID 1164, 2:49 PM session)

36,537 Procmon events — all consistent with legitimate WinRAR first-run behavior.

| Category | Observation |
| --- | --- |
| File Writes | version.dat (12 bytes) + 8 IE error page cache files (DNS failure artifacts) |
| Registry | 389 RegSetValue — WinRAR compression profiles in HKCU\SOFTWARE\WinRAR\Profiles\0–4 |
| Network Stack | Full stack loaded: ws2_32, wininet, winhttp, urlmon, dnsapi, mswsock |
| DNS Resolution | Failed — INetSim returned ICMP Port Unreachable for all queries |
| IE Error Cache | dnserrordiagoff[1], navcancl[1], ErrorPageTemplate[1] — DNS failure pages cached |
| Persistence | None detected — no Run/RunOnce/Service writes |
| VM Indicator | VBoxMRXNP.dll loaded — VirtualBox shared folders provider |

### 5.5 WinRAR.exe Baseline Session (PID 4964, 4:28 PM)

A second Procmon capture was taken at 4:28 PM for behavioral baselining of clean WinRAR. 38,259 events.

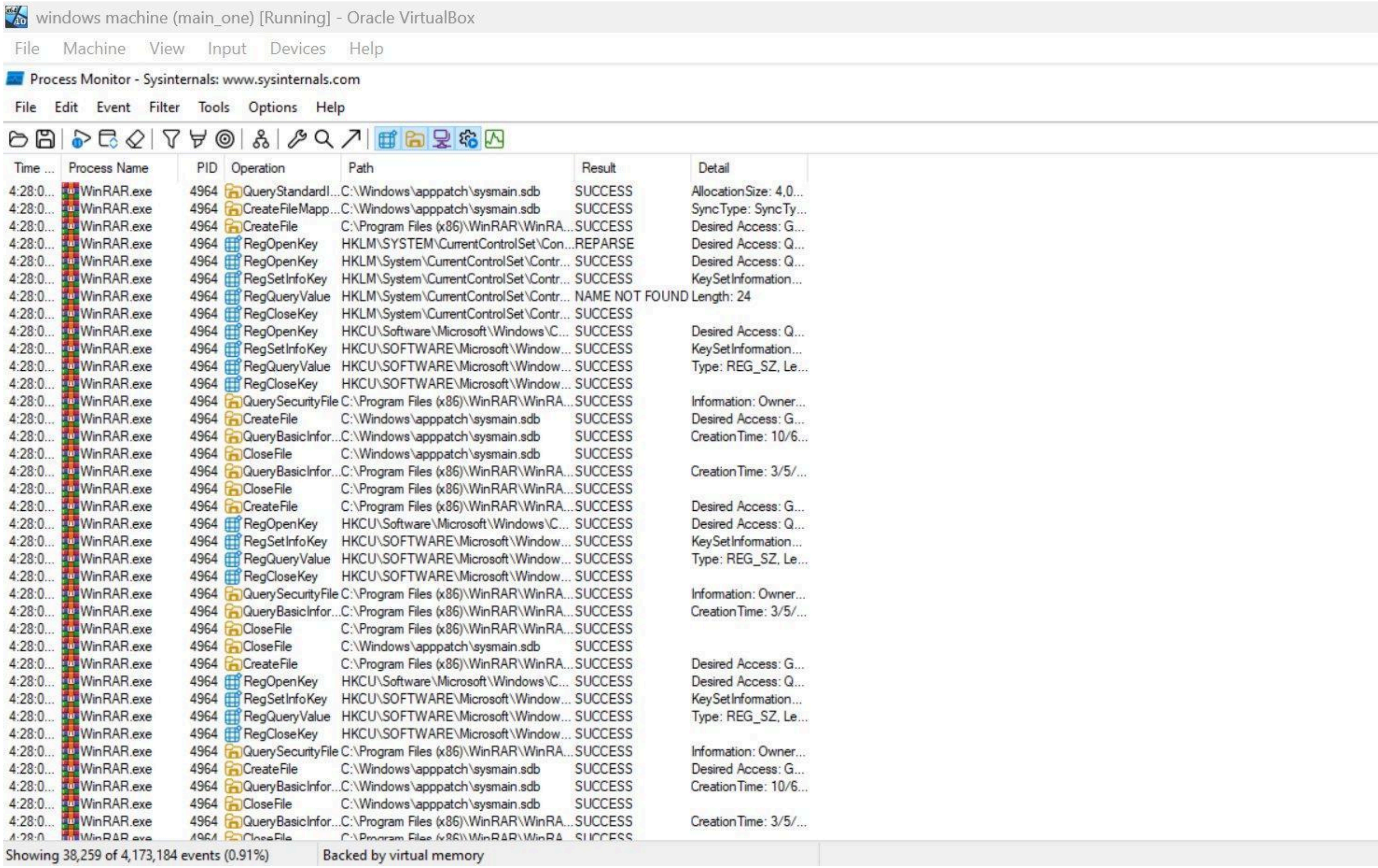



*Figure 13: Procmon — WinRAR.exe (PID 4964) at 4:28 PM — baseline session showing normal registry and file activity*

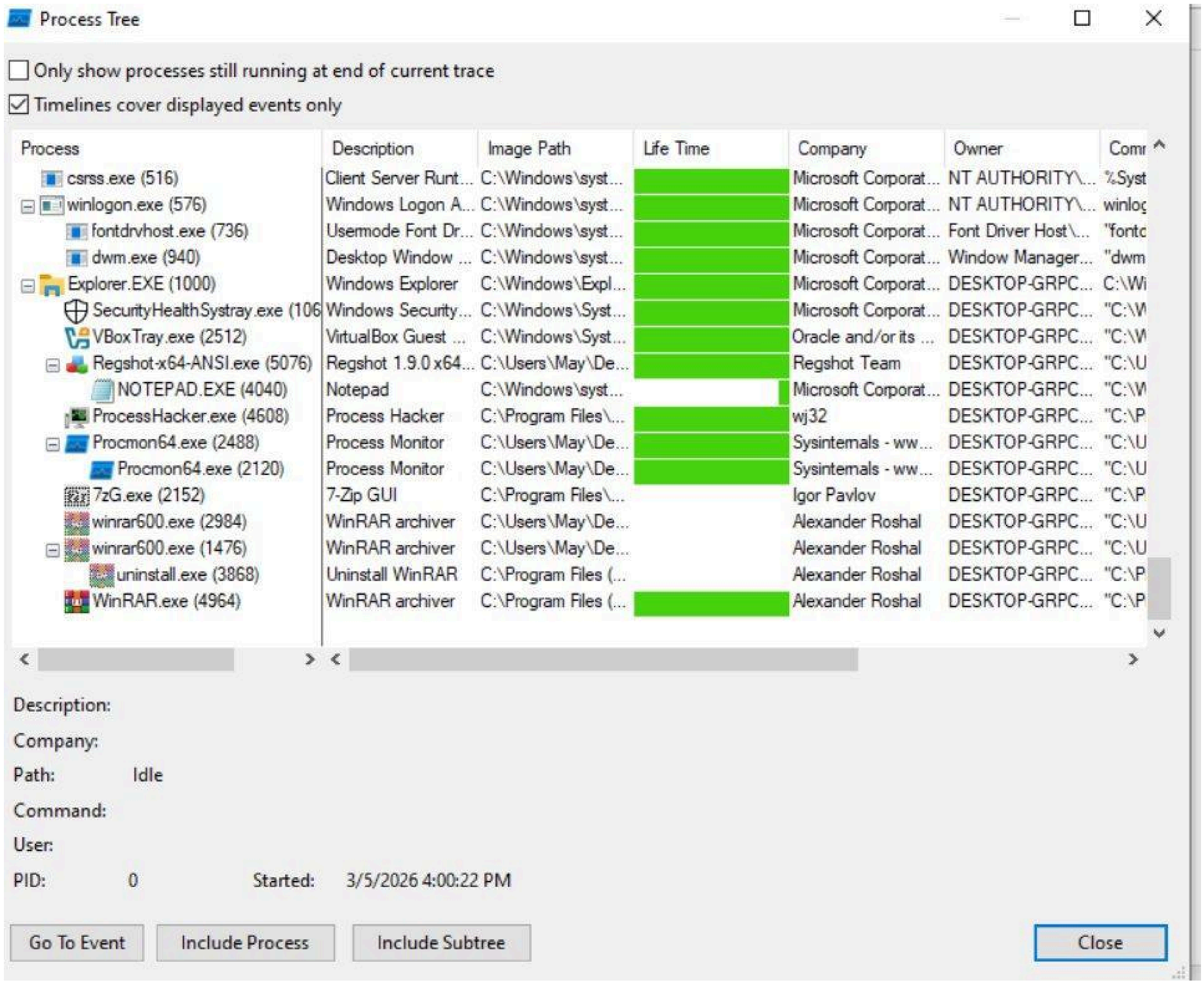



*Figure 14: Process Tree for 4:28 PM session — WinRAR.exe PID 4964 visible alongside analysis tools*

In this session, INetSim was not blocking connections and WinRAR made 3 real TCP outbound connections to rarlab.com (OVH Europe, Akamai CDN for CRL check, and Cloudflare/rarlab.com for the trial purchase nag page). All traffic was legitimate WinRAR update/license behavior.

---

## 6. Registry Analysis — Regshot

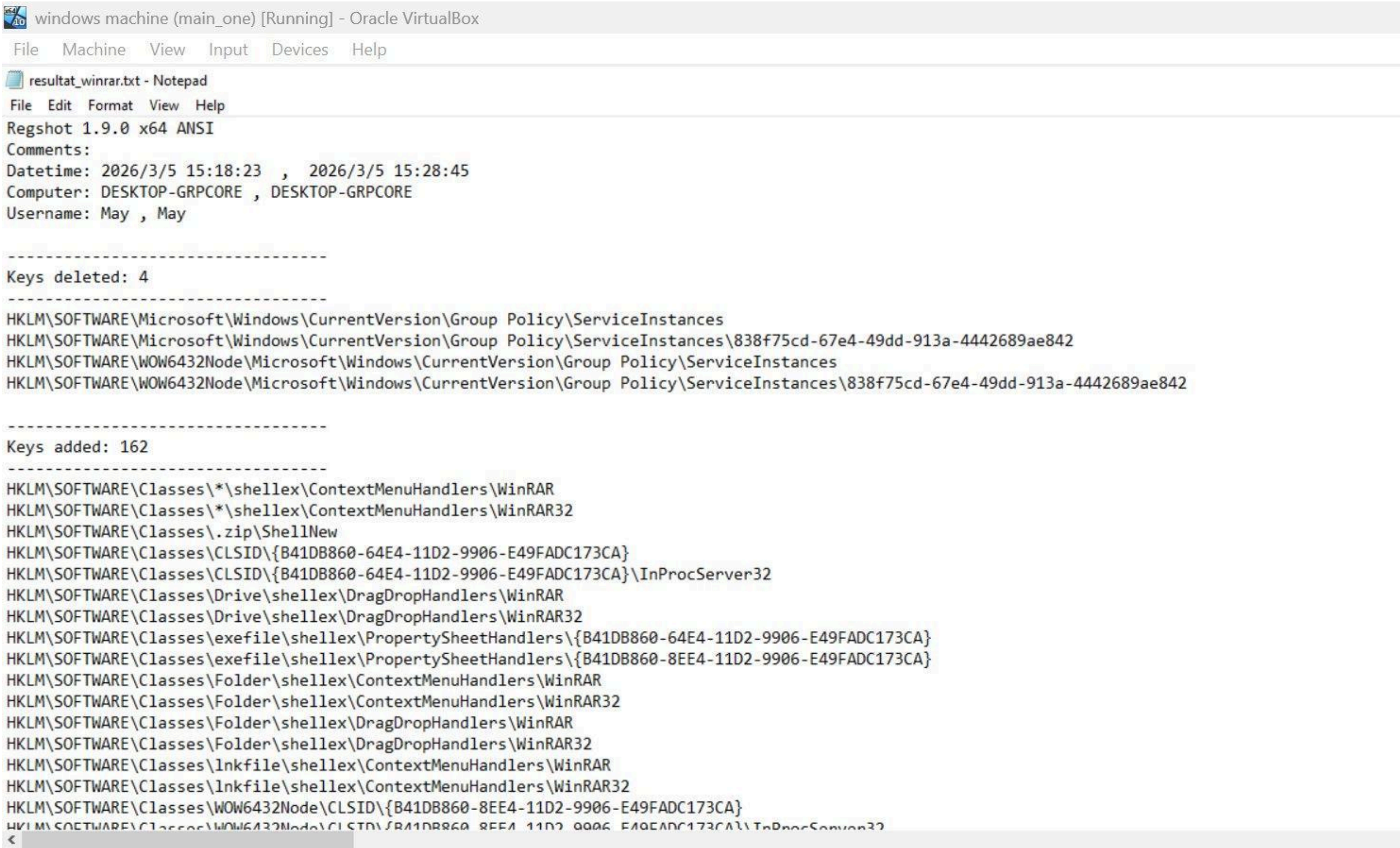
Three Regshot snapshots were taken: clean baseline, post-installation (13:35–13:50), and post-first-use (15:18–15:28).

### 6.1 Snapshot 1 — Post-Installation (1,646 changes)

| Type | Count | Details |
|---|---|---|
| Keys Added | 172 | WinRAR shell extensions, file associations, CLSID registrations |
| Keys Deleted | 6 | Group Policy ServiceInstances GUID rotation (Windows routine, unrelated) |
| Shell Extensions | | HKLM\SOFTWARE\Classes*\shellex\ContextMenuHandlers\WinRAR (right-click integration) |
| CLSID | | HKLM\SOFTWARE\Classes\CLSID\{B41DB860-64E4-11D2-9906-E49FADC173CA}\InProcServer32 |
| Certificate | | GlobalSign Root CA D69B561148F01C77 — WinRAR signature verification |
| Persistence | NONE | No Run/RunOnce/Services/Scheduled Tasks |

### 6.2 Snapshot 2 — Post-Use (904 changes)

| Type | Count | Details |
|---|---|---|
| Keys Added | 162 | WinRAR profiles + shell keys repeated |
| Keys Deleted | 4 | Group Policy ServiceInstances (routine) |
| WinRAR Profiles | 5 | HKCU\SOFTWARE\WinRAR\Profiles\0–4 with all compression settings |
| IdentityCRL NegativeCache | 1 | Watson telemetry auth failure — unrelated to sample |
| UserAssist ROT13 | | Confirms: Regshot ×3, Process Hacker ×2, Procmon64 ×2 launches |
| Persistence | NONE | No Run/RunOnce/Services/Scheduled Tasks |




```
Regshot 1.9.0 x64 ANSI
Comments:
Datetime: 2026/3/5 15:18:23  ,  2026/3/5 15:28:45
Computer: DESKTOP-GRPCORE , DESKTOP-GRPCORE
Username: May , May

----------------------------------
Keys deleted: 4
----------------------------------
HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Group Policy\ServiceInstances
HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Group Policy\ServiceInstances\838f75cd-67e4-49dd-913a-4442689ae842
HKLM\SOFTWARE\WOW6432Node\Microsoft\Windows\CurrentVersion\Group Policy\ServiceInstances
HKLM\SOFTWARE\WOW6432Node\Microsoft\Windows\CurrentVersion\Group Policy\ServiceInstances\838f75cd-67e4-49dd-913a-4442689ae842

----------------------------------
Keys added: 162
----------------------------------
HKLM\SOFTWARE\Classes\*\shellex\ContextMenuHandlers\WinRAR
HKLM\SOFTWARE\Classes\*\shellex\ContextMenuHandlers\WinRAR32
HKLM\SOFTWARE\Classes\.zip\ShellNew
HKLM\SOFTWARE\Classes\CLSID\{B41DB860-64E4-11D2-9906-E49FADC173CA}
HKLM\SOFTWARE\Classes\CLSID\{B41DB860-64E4-11D2-9906-E49FADC173CA}\InProcServer32
HKLM\SOFTWARE\Classes\Drive\shellex\DragDropHandlers\WinRAR
HKLM\SOFTWARE\Classes\Drive\shellex\DragDropHandlers\WinRAR32
HKLM\SOFTWARE\Classes\exefile\shellex\PropertySheetHandlers\{B41DB860-64E4-11D2-9906-E49FADC173CA}
HKLM\SOFTWARE\Classes\exefile\shellex\PropertySheetHandlers\{B41DB860-8EE4-11D2-9906-E49FADC173CA}
HKLM\SOFTWARE\Classes\Folder\shellex\ContextMenuHandlers\WinRAR
HKLM\SOFTWARE\Classes\Folder\shellex\ContextMenuHandlers\WinRAR32
HKLM\SOFTWARE\Classes\Folder\shellex\DragDropHandlers\WinRAR
HKLM\SOFTWARE\Classes\Folder\shellex\DragDropHandlers\WinRAR32
HKLM\SOFTWARE\Classes\lnkfile\shellex\ContextMenuHandlers\WinRAR
HKLM\SOFTWARE\Classes\lnkfile\shellex\ContextMenuHandlers\WinRAR32
HKLM\SOFTWARE\Classes\WOW6432Node\CLSID\{B41DB860-8EE4-11D2-9906-E49FADC173CA}
```

*Figure 16: Regshot second comparison output (15:18–15:28) — WinRAR keys added, no persistence mechanisms*

---

## 7. Network Analysis — Wireshark

Wireshark ran on the Ubuntu host (enp0s3). All DNS from the Windows VM (192.168.236.20) was directed to INetSim (192.168.236.10). Every query returned ICMP Port Unreachable — INetSim blocked all resolution.

### 7.1 Key DNS Queries

| Domain | Type | Response | Significance |
|---|---|---|---|
| wdcp.microsoft.com | A | ICMP Unreachable | Windows Delivery Optimization |
| dns.msftncsi.com | PTR+A | ICMP Unreachable | Microsoft Network Connectivity check |
| cp801.prod.do.dsp.mp.microsoft.com | A | ICMP Unreachable | Windows Update/BITS |
| ctldl.windowsupdate.com | A | ICMP Unreachable | Certificate Trust List download |

| Domain | Type | Response | Significance |
|---|---|---|---|
| au.download.windowsupdate.com | A | ICMP Unreachable | Windows Update |
| notifier.win-rar.com | A | ICMP Unreachable | ⚠ MALICIOUS — C2/notification — win-rar.com infrastructure |
| 10.236.168.192.in-addr.arpa | PTR | ICMP Unreachable | Reverse DNS for VM IP |

**Critical: notifier.win-rar.com** — This domain belongs to the win-rar.com typosquatting infrastructure, not the legitimate WinRAR publisher. Its DNS query during sample execution confirms a C2 or notification callback attempt by the malicious component. INetSim blocked the resolution.

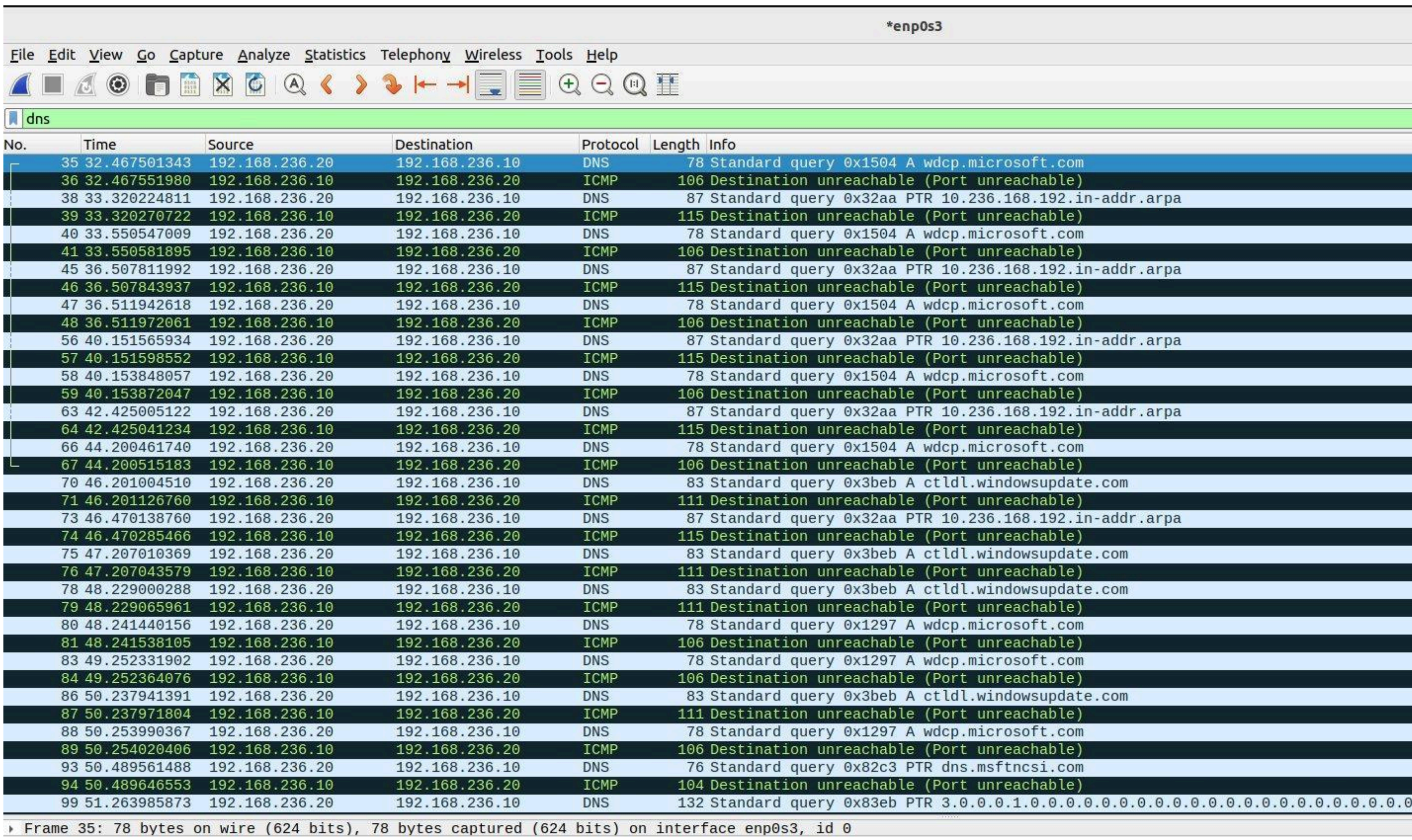
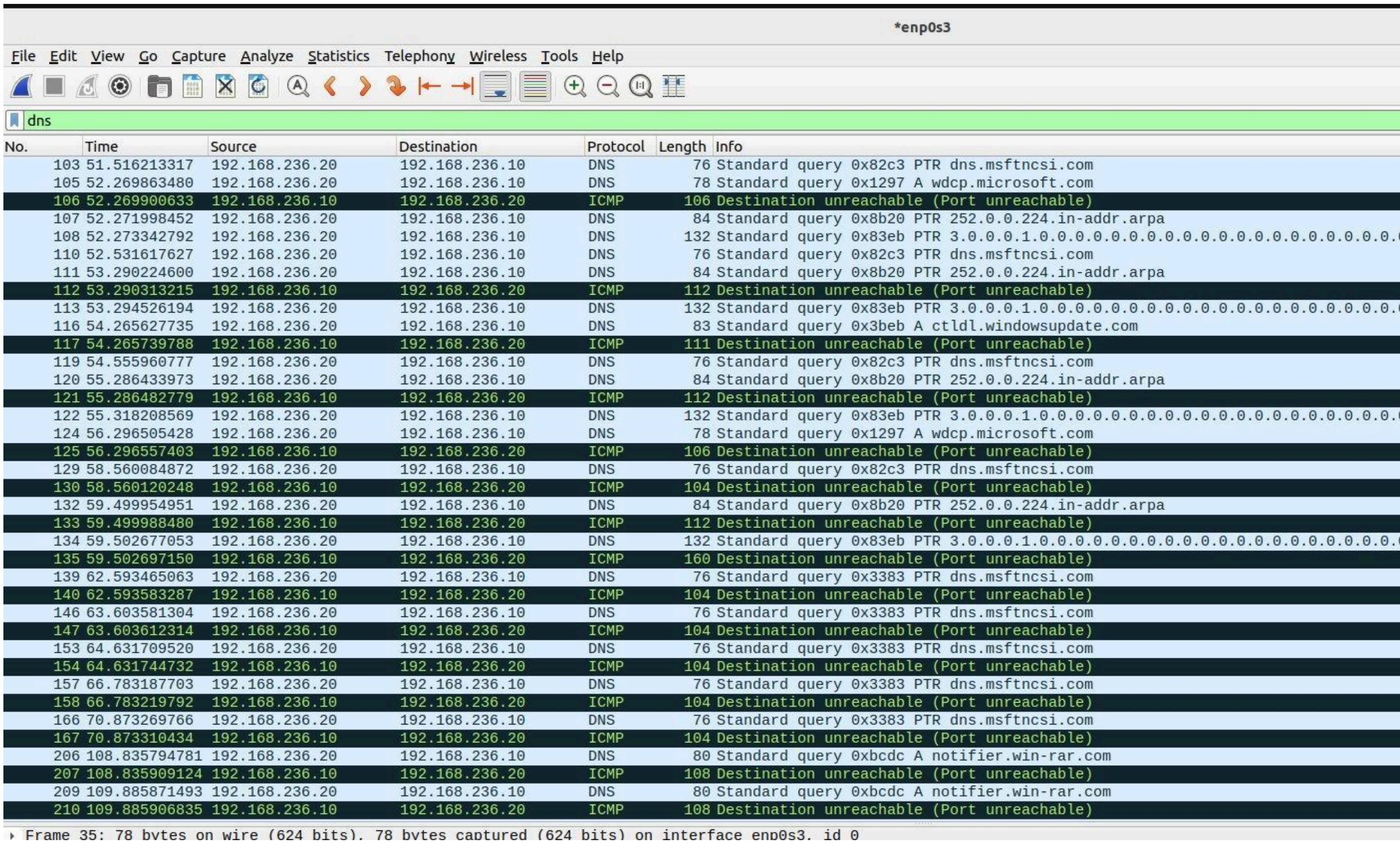



*Figure 17: Wireshark — early DNS traffic showing wdcp.microsoft.com and ctldl.windowsupdate.com queries with ICMP unreachable responses*



*enp0s3

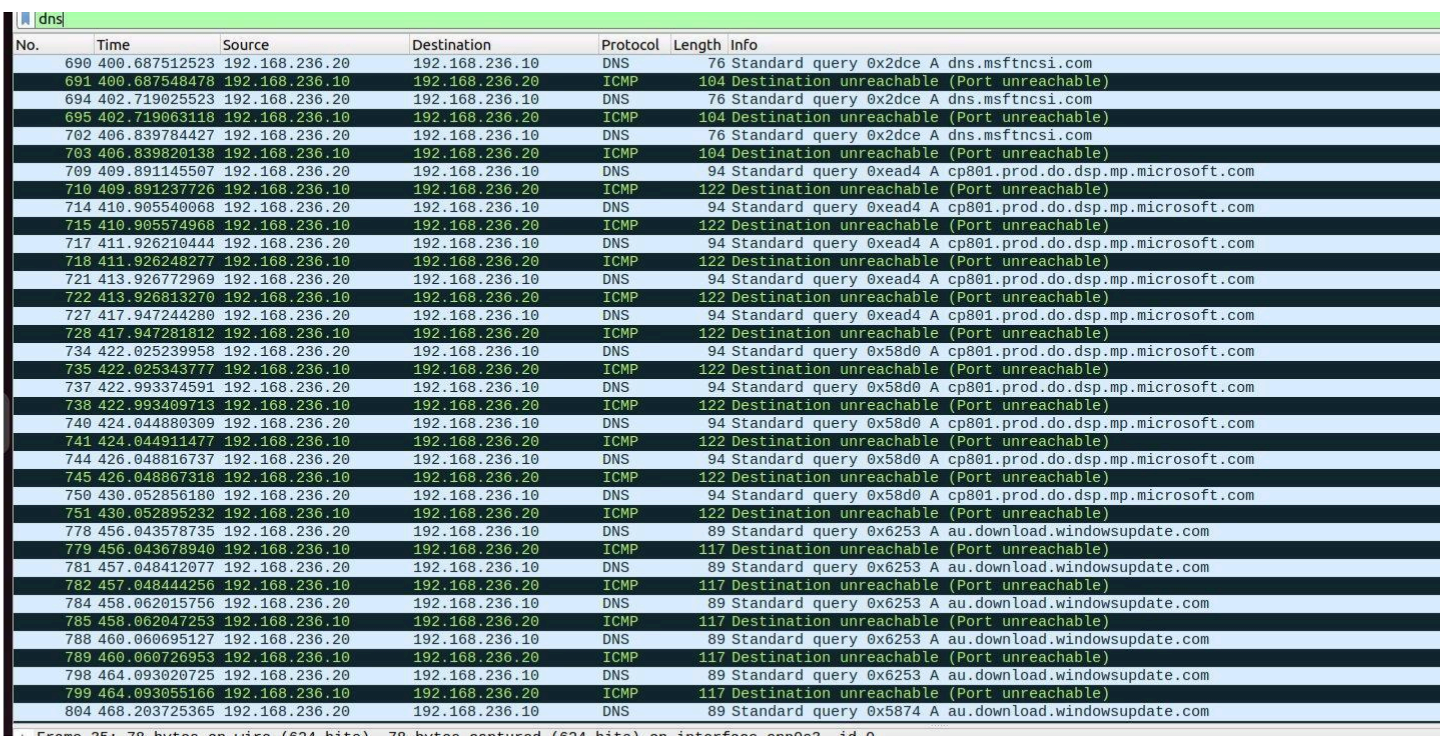
File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help

dns

| No. | Time | Source | Destination | Protocol | Length | Info |
|---|---|---|---|---|---|---|
| 103 | 51.516213317 | 192.168.236.20 | 192.168.236.10 | DNS | 76 | Standard query 0x82c3 PTR dns.msftncsi.com |
| 105 | 52.269863480 | 192.168.236.20 | 192.168.236.10 | DNS | 78 | Standard query 0x1297 A wdcp.microsoft.com |
| 106 | 52.269900633 | 192.168.236.10 | 192.168.236.20 | ICMP | 106 | Destination unreachable (Port unreachable) |
| 107 | 52.271998452 | 192.168.236.20 | 192.168.236.10 | DNS | 84 | Standard query 0x8b20 PTR 252.0.0.224.in-addr.arpa |
| 108 | 52.273342792 | 192.168.236.20 | 192.168.236.10 | DNS | 132 | Standard query 0x83eb PTR 3.0.0.0.1.0.0.0.0.0.0.0.0.0.0.0.0.0.0.0.0.0.0.0.0.0 |
| 110 | 52.531617627 | 192.168.236.20 | 192.168.236.10 | DNS | 76 | Standard query 0x82c3 PTR dns.msftncsi.com |
| 111 | 53.290224600 | 192.168.236.20 | 192.168.236.10 | DNS | 84 | Standard query 0x8b20 PTR 252.0.0.224.in-addr.arpa |
| 112 | 53.290313215 | 192.168.236.10 | 192.168.236.20 | ICMP | 112 | Destination unreachable (Port unreachable) |
| 113 | 53.294526194 | 192.168.236.20 | 192.168.236.10 | DNS | 132 | Standard query 0x83eb PTR 3.0.0.0.1.0.0.0.0.0.0.0.0.0.0.0.0.0.0.0.0.0.0.0.0.0 |
| 116 | 54.265627735 | 192.168.236.20 | 192.168.236.10 | DNS | 83 | Standard query 0x3beb A ctldl.windowsupdate.com |
| 117 | 54.265739788 | 192.168.236.10 | 192.168.236.20 | ICMP | 111 | Destination unreachable (Port unreachable) |
| 119 | 54.555960777 | 192.168.236.20 | 192.168.236.10 | DNS | 76 | Standard query 0x82c3 PTR dns.msftncsi.com |
| 120 | 55.286433973 | 192.168.236.20 | 192.168.236.10 | DNS | 84 | Standard query 0x8b20 PTR 252.0.0.224.in-addr.arpa |
| 121 | 55.286482779 | 192.168.236.10 | 192.168.236.20 | ICMP | 112 | Destination unreachable (Port unreachable) |
| 122 | 55.318208569 | 192.168.236.20 | 192.168.236.10 | DNS | 132 | Standard query 0x83eb PTR 3.0.0.0.1.0.0.0.0.0.0.0.0.0.0.0.0.0.0.0.0.0.0.0.0.0 |
| 124 | 56.296505428 | 192.168.236.20 | 192.168.236.10 | DNS | 78 | Standard query 0x1297 A wdcp.microsoft.com |
| 125 | 56.296557403 | 192.168.236.10 | 192.168.236.20 | ICMP | 106 | Destination unreachable (Port unreachable) |
| 129 | 58.560084872 | 192.168.236.20 | 192.168.236.10 | DNS | 76 | Standard query 0x82c3 PTR dns.msftncsi.com |
| 130 | 58.560120248 | 192.168.236.10 | 192.168.236.20 | ICMP | 104 | Destination unreachable (Port unreachable) |
| 132 | 59.499954951 | 192.168.236.20 | 192.168.236.10 | DNS | 84 | Standard query 0x8b20 PTR 252.0.0.224.in-addr.arpa |
| 133 | 59.499988480 | 192.168.236.10 | 192.168.236.20 | ICMP | 112 | Destination unreachable (Port unreachable) |
| 134 | 59.502677053 | 192.168.236.20 | 192.168.236.10 | DNS | 132 | Standard query 0x83eb PTR 3.0.0.0.1.0.0.0.0.0.0.0.0.0.0.0.0.0.0.0.0.0.0.0.0.0 |
| 135 | 59.502697150 | 192.168.236.10 | 192.168.236.20 | ICMP | 160 | Destination unreachable (Port unreachable) |
| 139 | 62.593465063 | 192.168.236.20 | 192.168.236.10 | DNS | 76 | Standard query 0x3383 PTR dns.msftncsi.com |
| 140 | 62.593583287 | 192.168.236.10 | 192.168.236.20 | ICMP | 104 | Destination unreachable (Port unreachable) |
| 146 | 63.603581304 | 192.168.236.20 | 192.168.236.10 | DNS | 76 | Standard query 0x3383 PTR dns.msftncsi.com |
| 147 | 63.603612314 | 192.168.236.10 | 192.168.236.20 | ICMP | 104 | Destination unreachable (Port unreachable) |
| 153 | 64.631709520 | 192.168.236.20 | 192.168.236.10 | DNS | 76 | Standard query 0x3383 PTR dns.msftncsi.com |
| 154 | 64.631744732 | 192.168.236.10 | 192.168.236.20 | ICMP | 104 | Destination unreachable (Port unreachable) |
| 157 | 66.783187703 | 192.168.236.20 | 192.168.236.10 | DNS | 76 | Standard query 0x3383 PTR dns.msftncsi.com |
| 158 | 66.783219792 | 192.168.236.10 | 192.168.236.20 | ICMP | 104 | Destination unreachable (Port unreachable) |
| 166 | 70.873269766 | 192.168.236.20 | 192.168.236.10 | DNS | 76 | Standard query 0x3383 PTR dns.msftncsi.com |
| 167 | 70.873310434 | 192.168.236.10 | 192.168.236.20 | ICMP | 104 | Destination unreachable (Port unreachable) |
| 206 | 108.835794781 | 192.168.236.20 | 192.168.236.10 | DNS | 80 | Standard query 0xbcdc A notifier.win-rar.com |
| 207 | 108.835909124 | 192.168.236.10 | 192.168.236.20 | ICMP | 108 | Destination unreachable (Port unreachable) |
| 209 | 109.885871493 | 192.168.236.20 | 192.168.236.10 | DNS | 80 | Standard query 0xbcdc A notifier.win-rar.com |
| 210 | 109.885906835 | 192.168.236.10 | 192.168.236.20 | ICMP | 108 | Destination unreachable (Port unreachable) |

Frame 35: 78 bytes on wire (624 bits), 78 bytes captured (624 bits) on interface enp0s3, id 0

*Figure 18: Wireshark — continued DNS traffic with multiple Microsoft telemetry and update domains queried*



dns

| No. | Time | Source | Destination | Protocol | Length | Info |
|---|---|---|---|---|---|---|
| 690 | 400.687512523 | 192.168.236.20 | 192.168.236.10 | DNS | 76 | Standard query 0x2dce A dns.msftncsi.com |
| 691 | 400.687548478 | 192.168.236.10 | 192.168.236.20 | ICMP | 104 | Destination unreachable (Port unreachable) |
| 694 | 402.719025523 | 192.168.236.20 | 192.168.236.10 | DNS | 76 | Standard query 0x2dce A dns.msftncsi.com |
| 695 | 402.719063118 | 192.168.236.10 | 192.168.236.20 | ICMP | 104 | Destination unreachable (Port unreachable) |
| 702 | 406.839784427 | 192.168.236.20 | 192.168.236.10 | DNS | 76 | Standard query 0x2dce A dns.msftncsi.com |
| 703 | 406.839820138 | 192.168.236.10 | 192.168.236.20 | ICMP | 104 | Destination unreachable (Port unreachable) |
| 709 | 409.891145507 | 192.168.236.20 | 192.168.236.10 | DNS | 94 | Standard query 0xead4 A cp801.prod.do.dsp.mp.microsoft.com |
| 710 | 409.891237726 | 192.168.236.10 | 192.168.236.20 | ICMP | 122 | Destination unreachable (Port unreachable) |
| 714 | 410.905540068 | 192.168.236.20 | 192.168.236.10 | DNS | 94 | Standard query 0xead4 A cp801.prod.do.dsp.mp.microsoft.com |
| 715 | 410.905574968 | 192.168.236.10 | 192.168.236.20 | ICMP | 122 | Destination unreachable (Port unreachable) |
| 717 | 411.926210444 | 192.168.236.20 | 192.168.236.10 | DNS | 94 | Standard query 0xead4 A cp801.prod.do.dsp.mp.microsoft.com |
| 718 | 411.926248277 | 192.168.236.10 | 192.168.236.20 | ICMP | 122 | Destination unreachable (Port unreachable) |
| 721 | 413.926772969 | 192.168.236.20 | 192.168.236.10 | DNS | 94 | Standard query 0xead4 A cp801.prod.do.dsp.mp.microsoft.com |
| 722 | 413.926813270 | 192.168.236.10 | 192.168.236.20 | ICMP | 122 | Destination unreachable (Port unreachable) |
| 727 | 417.947244280 | 192.168.236.20 | 192.168.236.10 | DNS | 94 | Standard query 0xead4 A cp801.prod.do.dsp.mp.microsoft.com |
| 728 | 417.947281812 | 192.168.236.10 | 192.168.236.20 | ICMP | 122 | Destination unreachable (Port unreachable) |
| 734 | 422.025239958 | 192.168.236.20 | 192.168.236.10 | DNS | 94 | Standard query 0x58d0 A cp801.prod.do.dsp.mp.microsoft.com |
| 735 | 422.025343777 | 192.168.236.10 | 192.168.236.20 | ICMP | 122 | Destination unreachable (Port unreachable) |
| 737 | 422.993374591 | 192.168.236.20 | 192.168.236.10 | DNS | 94 | Standard query 0x58d0 A cp801.prod.do.dsp.mp.microsoft.com |
| 738 | 422.993409713 | 192.168.236.10 | 192.168.236.20 | ICMP | 122 | Destination unreachable (Port unreachable) |
| 740 | 424.044880309 | 192.168.236.20 | 192.168.236.10 | DNS | 94 | Standard query 0x58d0 A cp801.prod.do.dsp.mp.microsoft.com |
| 741 | 424.044911477 | 192.168.236.10 | 192.168.236.20 | ICMP | 122 | Destination unreachable (Port unreachable) |
| 744 | 426.048816737 | 192.168.236.20 | 192.168.236.10 | DNS | 94 | Standard query 0x58d0 A cp801.prod.do.dsp.mp.microsoft.com |
| 745 | 426.048867318 | 192.168.236.10 | 192.168.236.20 | ICMP | 122 | Destination unreachable (Port unreachable) |
| 750 | 430.052856180 | 192.168.236.20 | 192.168.236.10 | DNS | 94 | Standard query 0x58d0 A cp801.prod.do.dsp.mp.microsoft.com |
| 751 | 430.052895232 | 192.168.236.10 | 192.168.236.20 | ICMP | 122 | Destination unreachable (Port unreachable) |
| 778 | 456.043578735 | 192.168.236.20 | 192.168.236.10 | DNS | 89 | Standard query 0x6253 A au.download.windowsupdate.com |
| 779 | 456.043678940 | 192.168.236.10 | 192.168.236.20 | ICMP | 117 | Destination unreachable (Port unreachable) |
| 781 | 457.048412077 | 192.168.236.20 | 192.168.236.10 | DNS | 89 | Standard query 0x6253 A au.download.windowsupdate.com |
| 782 | 457.048444256 | 192.168.236.10 | 192.168.236.20 | ICMP | 117 | Destination unreachable (Port unreachable) |
| 784 | 458.062015756 | 192.168.236.20 | 192.168.236.10 | DNS | 89 | Standard query 0x6253 A au.download.windowsupdate.com |
| 785 | 458.062047253 | 192.168.236.10 | 192.168.236.20 | ICMP | 117 | Destination unreachable (Port unreachable) |
| 788 | 460.060695127 | 192.168.236.20 | 192.168.236.10 | DNS | 89 | Standard query 0x6253 A au.download.windowsupdate.com |
| 789 | 460.060726953 | 192.168.236.10 | 192.168.236.20 | ICMP | 117 | Destination unreachable (Port unreachable) |
| 798 | 464.093020725 | 192.168.236.20 | 192.168.236.10 | DNS | 89 | Standard query 0x6253 A au.download.windowsupdate.com |
| 799 | 464.093055166 | 192.168.236.10 | 192.168.236.20 | ICMP | 117 | Destination unreachable (Port unreachable) |
| 804 | 468.203725365 | 192.168.236.20 | 192.168.236.10 | DNS | 89 | Standard query 0x5874 A au.download.windowsupdate.com |

*Figure 19: Wireshark — notifier.win-rar.com DNS queries (frames 207–210) — the key malicious C2 domain*

## 8. MITRE ATT&CK Mapping

| Tactic | Technique ID | Technique Name | Evidence |
|---|---|---|---|
| Initial Access | T1566 / Drive-by | Phishing / Drive-by Download | Typosquatting domain win-rar.com delivering malicious installer via Chrome |
| Execution | T1059 | Command and Scripting Interpreter | GetCommandLineW/A imported; embedded BAT script |
| Execution | T1204.002 | User Execution: Malicious File | User double-clicked winrar600.exe thinking it was a legitimate installer |
| Defense Evasion | T1497 | Virtualization/Sandbox Evasion | GlobalMemoryStatus, GetNativeSystemInfo imported for VM detection |
| Defense Evasion | T1497.001 | System Checks | FindWindowW/FindWindowExW — debugger window detection |
| Defense Evasion | T1027.002 | Software Packing | .rsrc entropy 7.77; VirtualProtect/VirtualAlloc imported |
| Defense Evasion | T1027.007 | Dynamic API Resolution | LoadLibraryW + GetProcAddress to hide imports |
| Defense Evasion | T1070.006 | Indicator Removal: Timestomp | SetFileTime, SetFileAttributesW imported |
| Defense Evasion | T1134 | Access Token Manipulation | OpenProcessToken, AdjustTokenPrivileges, DuplicateToken |
| Defense Evasion | T1055.011 | Extra Window Memory Injection | SetWindowLongW, GetWindowLongW, SetWindowLongPtrW |
| Defense Evasion | T1222 | File/Dir Permissions Modification | SetFileSecurityW@ADVAPI32 |
| Defense Evasion | T1218 | System Binary Proxy Execution (LOLBin) | mpcmdrun.exe, regedit.exe, expand, explorer strings present |
| Defense Evasion | T1036 | Masquerading | Named winrar600.exe; carries legitimate (expired) WinRAR cert |

| Tactic | Technique ID | Technique Name | Evidence |
|---|---|---|---|
| Defense Evasion | T1480 | Execution Guardrails (Mutex) | CreateMutexW — checks if machine already infected |
| Discovery | T1518.001 | Security Software Discovery | Queries registry for 10+ AV products |
| Discovery | T1082 | System Information Discovery | GlobalMemoryStatus, GetNativeSystemInfo |
| Discovery | T1007 | System Service Discovery | SYSTEM\CurrentControlSet\Services\avgntflt |
| Discovery | T1083 | File and Directory Discovery | FindFirstFileW, GetLogicalDrives, SHGetSpecialFolderLocation |
| Discovery | T1012 | Query Registry | Extensive registry enumeration |
| Discovery | T1033 | System Owner/User Discovery | CheckTokenMembership, OpenProcessToken |
| Collection | T1113 | Screen Capture | GetDesktopWindow, GetDC, CreateCompatibleBitmap, BitBlt |
| Command & Control | T1102 | Web Service (potential) | facebook.com domain hardcoded in extracted file |
| Command & Control | T1573 | Encrypted Channel | AES + SHA-256 crypto constants; CryptAcquireContextW |
| Command & Control | T1568 / C2 | C2 Callback | DNS query to notifier.win-rar.com during runtime |
| Persistence | T1547.001 | Registry Run Keys (potential) | Autostart registry reference found in extracted file |

# 9. Indicators of Compromise (IOCs)

## 9.1 File Hashes

| Type | Value | Description |
|---|---|---|
| MD5 | c74862e16bcc2b0e02cadb7ab14e3cd6 | winrar600.exe — trojanized installer |
| SHA-256 | aff4bb9b15bccff67a112a7857d28d3f2f436e2e42f11be14930fe496269d573 | winrar600.exe — primary sample |
| SHA-256 | 1317d70682bd11e5d320af850d6ecbb5a70c200d626ec7bf69c47566894db515 | Extracted PE (WinRAR.exe or component) |
| SHA-256 | 35a21f1aebf8ea0ab9be1814131fec1fa079d91b701e505054b69eccbdfd0732 | Extracted PE component |

| Type | Value | Description |
|---|---|---|
| MD5 (BTC wallet) | 3a3f7ffeafea443b95cb1568f32d9ffd | Found in 7zxa.dll — possible BTC wallet reference |

## 9.2 Network IOCs

| Type | Value | Verdict | Notes |
|---|---|---|---|
| Domain | win-rar.com | MALICIOUS | Primary typosquatting domain — delivery + C2 |
| Domain | notifier.win-rar.com | MALICIOUS | C2/notification callback domain — queried at runtime |
| Domain | shop.win-rar.com | SUSPICIOUS | E-commerce domain on same infrastructure |
| URL | https://www.win-rar.com/postdownload.html?&L=0&Version=32bit | MALICIOUS | Download origin URL (from Chrome proxy log) |
| URL | https://www.win-rar.com/buyredirect.html?L=0&BL=0&src=wrr&arch=32&ver=600H | SUSPICIOUS | Embedded in installer |
| IP | 51.195.68.163 | SUSPICIOUS | OVH Europe — win-rar.com hosting server |
| IP | 51.195.68.162 | SUSPICIOUS | OVH Europe — related IP same /24 |
| IP | 104.18.20.213 / 104.18.21.226 | BENIGN | Cloudflare — rarlab.com CDN (legitimate WinRAR) |

## 9.3 Email IOCs

| Email | Source | Notes |
|---|---|---|
| sales@win-razyr.com | Order.htm (extracted from SFX) | Typosquat contact email — win-razyr.com |
| sales@win-rar.com | registration.php (downloaded file) | Win-rar.com contact — malicious domain |
| n@inclist.txt | Rar.txt text file | Internal list file reference |
| x@exlist.txt | Rar.txt text file | Internal list file reference |

## 9.4 File & Registry IOCs

| Type | Value | Notes |
|---|---|---|
| File | winrar600.exe | Trojan — social engineering name |
| File | c74862e16bcc2b0e02cadb7ab14e3cd6.zip | Delivery ZIP container |
| Path | C:\Users\May\Desktop\winrar600.exe | Drop location after ZIP extraction |
| Path | C:\Users\May\AppData\Roaming\WinRAR\version.dat | WinRAR first-run artifact (12 bytes) |
| Registry | HKCU\SOFTWARE\WinRAR\Profiles\0–4 | WinRAR compression profiles — normal install trace |
| Registry | HKLM\SOFTWARE\Classes*\shellex\ContextMenuHandlers\WinRAR | Shell integration — normal install trace |
| AV Check | SOFTWARE\Data Fellows\F-Secure\Anti-Virus | Malware checks for F-Secure |
| AV Check | SOFTWARE\ESet\NOD\CurrentVersion\Info | Malware checks for ESET |
| AV Check | SYSTEM\CurrentControlSet\Services\avgntflt | Malware checks for Avira driver |

---

# 10. Recommendations

## 10.1 Immediate Actions — SusieHost

- Isolate SusieHost from the network immediately — Device Action was Allowed, sample executed
- Quarantine winrar600.exe from the endpoint
- Take forensic image (disk + memory) before any remediation
- Inspect persistence: Run/RunOnce keys, Startup folders, scheduled tasks XML, WMI subscriptions, and services
- Reset Susie2020 credentials — potential data exfiltration via screen capture or credential theft APIs
- Review authentication logs for lateral movement from 172.16.17.5 to other internal hosts
- Check for files timestomped using SetFileTime — look for files with creation dates inconsistent with modification dates

## 10.2 Further Analysis

- Re-run Procmon with filter: Process Name = winrar600.exe to capture the actual trojan operations
- Run the sample in a bare-metal or hardened non-VirtualBox environment to prevent VM detection dormancy (or use VBoxHardenedLoader / hide VM artifacts)
- Submit hash to VirusTotal and cross-reference with APT_DustSquad campaign intelligence (YARA hit with 0.4 confidence)

- Perform deeper static analysis: disassemble the 2.6 MB overlay at offset 411,136 — this is the most likely location of the secondary payload
- Investigate the facebook.com domain reference in extracted files — could indicate social-media-based C2 (T1102)
- Analyze Order.htm and the sales@win-razyr.com email address — additional typosquat infrastructure

### 10.3 Organizational Controls

- Block at DNS/proxy: win-rar.com, notifier.win-rar.com, shop.win-rar.com across the entire organization
- Block IP: 51.195.68.163 and 51.195.68.162 at the perimeter firewall
- Hash block: Add MD5 c74862e16bcc2b0e02cadb7ab14e3cd6 to EDR/AV block lists immediately
- Proxy policy: Alert on downloads from domains impersonating well-known software vendors
- User awareness: Train users to verify software download domains — the correct WinRAR source is rarlab.com, not win-rar.com
- Application whitelisting: Block unsigned or untrusted executables running from Desktop/Downloads/Temp
- EDR rules: Alert on any process that queries 10+ AV-related registry keys within 1 second — this is a clear AV fingerprinting signature

---

## Appendix A — Tool Output Summary

| Tool / Source | Data Captured | Key Finding |
|---|---|---|
| LetsDefend (SOC104) | EventID 84, March 21 2021 | winrar600.exe allowed to execute on SusieHost — not quarantined |
| filescan.io (static) | 40 extracted files, 1 High Risk indicator | VM detect, AV fingerprint, screen capture, timestomp, YARA APT hit |
| Procmon — Logfile.CSV | 1,089 events, 7zG.exe PID 2648 | winrar600.exe dropped to Desktop from ZIP |
| Procmon — Logfile2.CSV | 36,537 events, WinRAR.exe PID 1164 | Network stack + INetSim DNS failure — notifier.win-rar.com queried |
| Procmon — 4:28 PM baseline | 38,259 events, WinRAR.exe PID 4964 | 3 clean TCP connections to rarlab.com — trial nag page downloaded |
| Regshot — Snapshot 1 | 1,646 changes, 13:35–13:50 | WinRAR installation footprint — no persistence |
| Regshot — Snapshot 2 | 904 changes, 15:18–15:28 | WinRAR profiles written — no persistence |
| Wireshark — enp0s3 | 800+ DNS frames | notifier.win-rar.com C2 query blocked; all others ICMP unreachable |

| Tool / Source | Data Captured | Key Finding |
|---|---|---|
| Process Hacker 2 | Process tree + memory | Full execution chain confirmed; VM artifacts visible |